A Note on Feedback-PRF Mode of KDF from NIST SP 800-108

Ritam Bhaumik[1] Avijit Dutta[2,3] Tetsu Iwata[4] Ashwin Jha[5]
Kazuhiko Minematsu[6] Mridul Nandi[7] Yu Sasaki[8] Meltem Sönmez Turan[9]
Stefano Tessaro[10]

[1] TII, Abu Dhabi, UAE, bhaumik.ritam@gmail.com
[2] Institute for Advancing Intelligence, TCG CREST, Kolkata, India,
[3] AcSIR, India, avirocks.dutta13@gmail.com
[4] Nagoya University, Nagoya, Japan, tetsu.iwata@nagoya-u.jp
[5] Ruhr-University Bochum, Bochum, Germany, ashwin.jha@ruhr-uni-bochum.de
[6] NEC Corporation, Kawasaki, Japan, k-minematsu@nec.com
[7] Indian Statistical Institute, Kolkata, Kolkata, India, mridul.nandi@gmail.com
[8] NTT Social Informatics Laboratories, Tokyo, Japan, yusk.sasaki@ntt.com
[9] National Institute of Standards and Technology, Gaithersburg, MD, USA, meltem.turan@nist.gov
[10] University of Washington, Seattle, WA, USA, tessaro@cs.washington.edu

Abstract

We consider FB-PRF, one of the key derivation functions defined in NIST SP 800-108 constructed from a pseudorandom function in a feedback mode. The standard allows some flexibility in the specification, and we show that one specific instance of FB-PRF allows an efficient distinguishing attack.

Keywords: Key derivation function; NIST SP 800-108; Feedback mode; Pseudorandomness.

1 Introduction

A key derivation function (KDF) is a cryptographic function that outputs multiple session keys or user keys from a single master key. Among various design approaches, we focus on the ones specified in NIST SP 800-108 [Che22], where KDFs are constructed based on pseudorandom functions (PRFs). KMAC, HMAC, or CMAC can be used as the PRF. When HMAC or CMAC is used, it defines three modes of operation, called a counter (CTR) mode, a feedback (FB) mode, and a double-pipeline (DP) mode. It further defines three strengthened modes when CMAC is used, which we write stCTR, stFB, and stDP, to mitigate a security issue of key control pointed out in a public comment by an Amazon team in [Nat22].

There are several security requirements of KDFs [Che22, Sect. 6], and one of the requirements is indistinguishability [Che22, Sect. 6.1], i.e., the outputs of the KDF should be computationally indistinguishable from truly random bit strings, assuming that the key-derivation key, i.e., the master key, is unknown to the adversary. This is implied by the security of the KDF as a PRF. Another important requirement is key control security, discussed in [Che22, Sect. 6.7], which can be seen as a variant of preimage security of the KDF in the known-key setting [BDI+25].

In this note, we focus on the indistinguishability security of one of the KDFs defined in [Che22]. Specifically, we consider FB-PRF, a feedback mode, where the underlying PRF can be HMAC, CMAC, or any other suitable PRF. The standard [Che22] allows some flexibility in the configuration when FB-PRF is used, and we show an efficient distinguishing attack against a specific instance of FB-PRF allowed in [Che22]. Our attack can be seen as a variant of the slide attack [BW99].

2 Preliminaries

Notation. Let ε be an empty string. For an integer $i \geq 0$, $\{0,1\}^i$ denotes the set of all bit strings of length i, and $\{0,1\}^*$ denotes the set of all bit strings of finite lengths (including ε). For an integer $i \geq 0$, 0^i denotes the bit string of i zero bits. For an integer $0 \leq i \leq 2^r - 1$, $\langle i \rangle_r$ denotes the encoding of i as an r-bit string. For a bit string X, its length in bits is written as $|X|$, and for $t \leq |X|$, the most significant t bits of X is written as $\mathtt{msb}_t(X)$. For bit strings X and Y, $X \,\|\, Y$ denotes their concatenation. A pseudorandon function $F : \{0,1\}^k \times \{0,1\}^* \to \{0,1\}^h$ is a keyed function, where k is the key length and h is the output length.

FB-PRF. We consider FB-F, which we also write FB[F], the feedback mode based on PRF F. It takes $K_{IN}, \mathit{Label}, \mathit{Context}, IV$, and L as input, and outputs K_{OUT}, where $|K_{OUT}| = L$. We write

$$K_{OUT} = \mathrm{FB}[F](K_{IN}, \mathit{Label}, \mathit{Context}, IV, L)\,.$$

- K_{IN} is the master key used as the PRF key. This is also called a key-derivation key.
- *Label* is a bit string that identifies the purpose for the derived keying material K_{OUT}.
- *Context* is a bit string containing the information related to K_{OUT}.
- IV is a bit string used as an initial value in computing the first iteration in the feedback mode. Let $iv = |IV|$ be its bit length.
- L is an integer specifying the bit length of the output K_{OUT}.
- K_{OUT} is a keying material that is output from the KDF.

The algorithm of FB[F] is provided in Fig. 1 and is illustrated in Fig. 2. The corresponding algorithm for the strengthened variant stFB[F] is also given in Fig. 1. The standard allows some flexibility in the specification.

- In FB[F], IV can be public, secret, or even an empty string. The length of IV is specified by the application or protocol using the KDF. In stFB[F], IV is not a part of the input and $K[0]$ $(= IV)$ is computed internally from $K_{IN}, \mathit{Label}, \mathit{Context}$, and L.
- In FB[F], the use of the block counter $\langle i \rangle_r$ (highlighted in gray in Figs. 1 and 2) is optional. In stFB[F], the block counter is required.

3 The Attack

We present a distinguishing attack on a specific instance of FB-PRF. We consider the case where IV is a public input with bit length $iv = h$, and the optional block counter is not used. The FB-PRF instance for this case, with an output length of $L = 3h$, is illustrated in Fig. 3.

Now assume that the adversary learns one input-output pair for this case, i.e., the adversary knows $(\mathit{Label}, \mathit{Context}, IV, L)$ and the corresponding $K_{OUT} = K[1] \,\|\, K[2] \,\|\, K[3]$ where

$$K_{OUT} = \mathrm{FB}[F](K_{IN}, \mathit{Label}, \mathit{Context}, IV, L)\,.$$

Then, the adversary immediately knows that the first $2h$ bits of $K'_{OUT} = K'[1] \,\|\, K'[2] \,\|\, K'[3]$ for the input $(\mathit{Label}, \mathit{Context}, IV', L)$ with $IV' = K[1]$ is $K[2] \,\|\, K[3]$. That is, for

$$K'_{OUT} = \mathrm{FB}[F](K_{IN}, \mathit{Label}, \mathit{Context}, IV', L)$$

```
Algorithm FB[F](K_IN, Label, Context, IV, L)
  s ← ⌈L/h⌉; K[0] ← IV
  if s > 2^32 − 1 then return ⊥
  for i = 1 to s do
    K[i] ← F(K_IN, K[i − 1] ∥⟨i⟩_r ∥ Label ∥ 0^8 ∥ Context ∥ L)
  K_OUT ← msb_L(K[1] ∥ ··· ∥ K[s])
  return K_OUT
```

```
Algorithm stFB[F](K_IN, Label, Context, L)                ▷ IV is not a part of the input
  s ← ⌈L/h⌉
  if s > 2^32 − 1 then return ⊥
  K[0] ← F(K_IN, Label ∥ 0^8 ∥ Context ∥ L)                ▷ K[0] is computed internally
  for i = 1 to s do
    K[i] ← F(K_IN, K[i − 1] ∥⟨i⟩_r ∥ Label ∥ 0^8 ∥ Context ∥ L)   ▷ ⟨i⟩_r is required
  K_OUT ← msb_L(K[1] ∥ ··· ∥ K[s])
  return K_OUT
```

Figure 1: Algorithms of FB[F] and stFB[F]. In FB[F], $\|\langle i\rangle_r$ is optional. In stFB[F], F is CMAC.

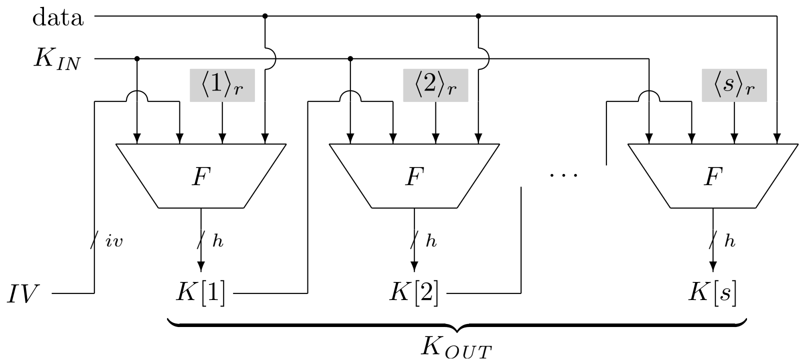

Figure 2: Illustration of FB[F], where data = $Label \,\|\, 0^8 \,\|\, Context \,\|\, L$.

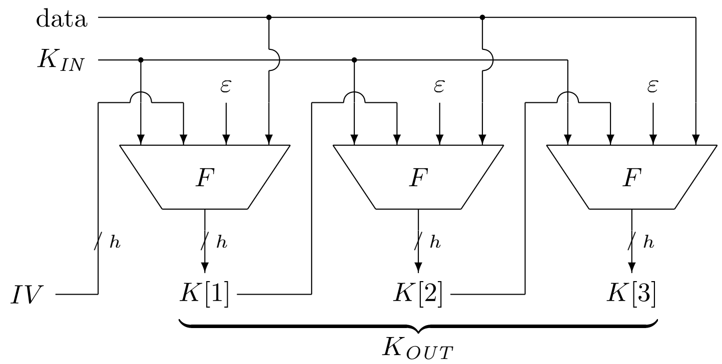

Figure 3: Illustration of FB[F], where $L = 3h$, $iv = h$, and the block counter is not used. Here, data = $Label \,\|\, 0^8 \,\|\, Context \,\|\, L$.

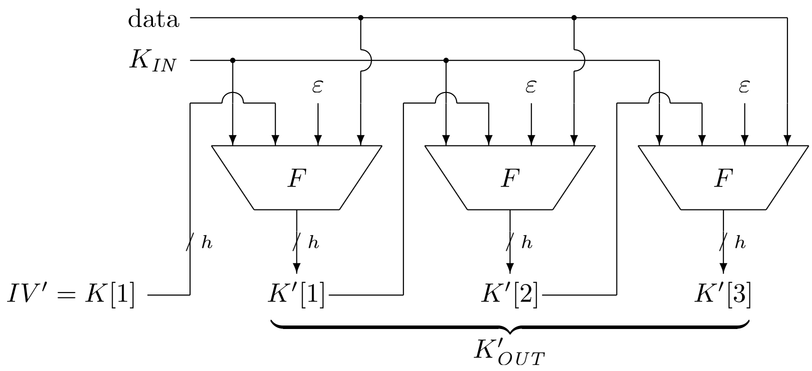

Figure 4: Observe that $K'[1] = K[2]$ and $K'[2] = K[3]$ hold.

with $IV' = K[1]$, it holds that $K'[1] \| K'[2] = K[2] \| K[3]$. See Fig. 4. If K_{OUT} and K'_{OUT} are chosen uniformly at random, this equality does not hold with an overwhelming probability, giving an efficient distinguishing attack.

4 Conclusions

This note shows that a specific instance of FB-PRF from [Che22] allows an efficient distinguishing attack. The attack works regardless of the choice of the PRF. There are various ways to avoid the vulnerability. For instance, the attack fails if the length of IV is different from h, if the protocol restricts the selection of IV to a small set of possible values, if the block counter is used, or if IV is derived from *Context* as in the strengthened mode.

We note that [SWG25] proves that the feedback mode using CMAC (stFB[CMAC] in our notation) is a PRF, and that FB[HMAC] is also a PRF. The latter result considers the case where IV is a fixed value and a block counter is not used. We also note that [BDI+25] proves the key control security of FB[HMAC], where IV is assumed to be defined by *Label* and L, and the block counter is not used. The papers [SWG25, BDI+25] study different setting than ours, and our findings do not contradict their results.

Acknowledgements

This is a follow-up work of [BDI+25], where the collaboration has initiated at Dagstuhl Seminar 24041, Symmetric Cryptography. We thank Aishwarya Thiruvengadam and Akiko Inoue for the early phase of the discussion. We also thank the authors of [SWG25] for feedback.

References

[BDI+25] Ritam Bhaumik, Avijit Dutta, Akiko Inoue, Tetsu Iwata, Ashwin Jha, Kazuhiko Minematsu, Mridul Nandi, Yu Sasaki, Meltem Sönmez Turan, and Stefano Tessaro. Cryptographic Treatment of Key Control Security – In Light of NIST SP 800-108. In Yael Tauman Kalai and Seny Kamara, editors, *CRYPTO 2025, Part V*, volume 16004 of *Lecture Notes in Computer Science*, pages 371–403. Springer, 2025. *(Cited on pp. 1 and 4.)*

[BW99] Alex Biryukov and David A. Wagner. Slide Attacks. In Lars R. Knudsen, editor, *FSE '99*, volume 1636 of *Lecture Notes in Computer Science*, pages 245–259. Springer, 1999. *(Cited on p. 1.)*

[Che22] Lily Chen. Recommendation for Key Derivation Using Pseudorandom Functions. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-108 Rev. 1, 8 2022. *(Cited on pp. 1 and 4.)*

[Nat22] National Institute of Standards and Technology. Public Comments and Resolutions on Draft NIST SP 800-108 Revision 1, Recommendation for Key Derivation Using Pseudorandom Functions. Available at `https://csrc.nist.gov/pubs/sp/800/108/r1/upd1/final`, 1 2022. *(Cited on p. 1.)*

[SWG25] Yaobin Shen, Lei Wang, and Dawu Gu. Security Analysis of NIST Key Derivation Using Pseudorandom Functions. *IACR Cryptol. ePrint Arch.*, 2025/815, 2025. *(Cited on p. 4.)*